IA22 - Analyse de Threat Intelligence en temps réel
Spécification Fonctionnelle et Technique

Document de conception - Version 1.0 - 19 octobre 2026 - Projet IA22

1. Objectif et Architecture Fonctionnelle

L'objectif est de mettre en place une chaîne automatisée de Cyber Threat Intelligence (CTI) capable de collecter, analyser et corréler en continu les renseignements sur les cybermenaces afin d'alimenter directement la base de connaissances de l'IA22. L'architecture fonctionnelle repose sur cinq couches : (1) Collecte continue des flux CTI (CERT/CSIRT, OSINT, SIEM, EDR, réputation), (2) Normalisation et enrichissement (déduplication, validation, contextualisation), (3) Extraction et analyse par IA (IoC, TTP, campagnes), (4) Base de connaissances IA22 (stockage structuré, indexation sémantique, traçabilité), (5) Exploitation opérationnelle (détection, corrélation, alertes prioritaires).

2. Données à extraire et Normalisation

Catégorie	Éléments	Utilité IA22	Standard
IoC	IP, domaines, URL, hash, artefacts	Identifier infra suspecte	STIX 2.1 Indicator
TTP	Techniques ATT&CK	Comprendre comportements	MITRE ATT&CK
Acteurs	Groupes, campagnes, malwares	Relier incidents	STIX Intrusion-Set
Vulnérabilités	CVE, EPSS, KEV	Prioriser correctifs	CVE / CVSS
Contexte	Source, date, confiance	Limiter faux positifs	TLP + Confidence

Normalisation : Tous les renseignements sont convertis en objets STIX 2.1 (Bundle). Les techniques sont normalisées avec MITRE ATT&CK; Enterprise. Partage via TAXII 2.1 Server.

3. Pipeline de Traitement Temps Réel

1. Ingestion événementielle : API Gateway -> Kafka topics cti.raw.* (feeds, internal, reports). Connecteurs TAXII poll ANSSI, CERT-FR, CISA, MISP, AlienVault OTX.

2. Extraction automatisée : Regex haute précision + modèle NER spaCy fine-tuné CTI + LLM local (Mistral) pour extraction TTP et mapping ATT&CK.; Parsing STIX, JSON, PDF.

3. Enrichissement contextuel : GeoIP, ASN, Whois, passive DNS, VirusTotal, Shodan, EPSS, CISA KEV, corrélation interne SIEM.

4. Corrélation : Moteur graphe Neo4j. Règles : même ASN + même TTP + fenêtre 24h = cluster campagne. Construction timeline attaque.

5. Validation : Score confiance = f(réputation source, fraîcheur, corroboration multi-source, cohérence technique). Seuil : <60 raw, 60-80 validated, >80 operational. IP partagée = contexte obligatoire.

6. Mise à jour IA22 : Upsert dans Neo4j (relations), Qdrant (embeddings sémantiques), OpenSearch (IoC avec TTL). Historisation complète avec rollback.

4. Modèle de Données Recommandé - IA22

Chaque renseignement utilise l'extension STIX 2.1 x_ia22 pour conserver compatibilité tout en ajoutant besoins IA22. Le modèle JSON de référence est le suivant :

```
{
  "type": "indicator",
  "spec_version": "2.1",
  "id": "indicator--a1b2c3d4-...",
  "created": "2026-10-19T14:00:00Z",
  "modified": "2026-10-19T14:00:00Z",
  "pattern": "[domain-name:value = 'example.com']",
  "indicator_types": ["malicious-activity"],
  "confidence": 85,
  "valid_from": "2026-10-19T14:00:00Z",
  "valid_until": "2026-11-18T14:00:00Z",
  "x_ia22_severity": "high",
  "x_ia22_category": "command_and_control",
  "x_ia22_ttps": ["T1071.001","T1105"],
  "x_ia22_campaigns": ["intrusion-set--apt29"],
  "x_ia22_provenance": {
    "source_reference": "cert-fr-2026-AVI-123",
    "source_reliability": "A (CERT)",
    "processing_version": "cti-pipeline-v2.1"
  },
  "x_ia22_validity_status": "validated"
}
```

5. Indicateurs de Performance (KPI)

KPI	Définition	Seuil cible	Mesure
Latence traitement	Publication -> indexation IA22	< 2 min (p95)	Kafka lag + timestamp
Fraîcheur	% renseignements encore pertinents	> 90%	valid_until > now
Précision extraction	IoC/TTP correctement identifiés	F1 > 0.92	Dataset annoté
Déduplication	Réduction doublons	> 75%	Bloom filter Redis
Faux positifs	% indicateurs mal classés	< 2%	Revue humaine
Traçabilité	Source + date vérifiables	100%	Provenance obligatoire

6. Sécurité et Gouvernance

• Validation et assainissement : Parser defang (hxxp), validation Pydantic stricte, sandbox LLM anti prompt injection, filtrage TLP.

• Séparation des données : 3 zones physiques/logiques - raw (Kafka), validated (OpenSearch), operational (API). Aucun passage direct raw->SOC.

• Versionning et journalisation : Chaque modification = nouvelle version dans Neo4j + journal immuable. Rollback via event_id.

• Expiration : Job Airflow quotidien - IP TTL 30j, domaine 90j, hash 365j, TTP permanent. Réévaluation si ré-observé.

• Contrôle d'accès et licences : RBAC, chiffrement TLS/mTLS, respect licences CTI (TLP:RED jamais partagé), audit.

• Validation humaine : HITL obligatoire pour confiance 70-85 ou action défensive bloquante (firewall, isolation EDR).

7. Architecture Technique Implémentable

Stack proposé : Kafka + Faust (streaming), OpenCTI/MISP connectors (TAXII 2.1), Python workers (stix2, spaCy, transformers), Neo4j (graphe de menaces), Qdrant (recherche sémantique), OpenSearch (IoC store), Redis (dedup), FastAPI (API IA22), Airflow (orchestration), Grafana (KPI). Déploiement via docker-compose pour POC, Kubernetes en production. L'API expose /indicators?confidence>80&valid;_now=true, /search/semantic pour LLM RAG, /correlate pour clusters. Le SOC consomme via connecteur SOAR générant règles Sigma/YARA automatiquement.

8. Résultat Attendu

IA22 dispose d'une base de connaissances actualisée en continu, capable de relier indicateurs techniques (IoC) aux comportements adverses (TTP) et aux campagnes. Cette approche transforme les flux CTI bruts en renseignements structurés, contextualisés, traçables et directement exploitables par les mécanismes de détection et d'aide à la décision. La base devient le pivot central pour la corrélation SIEM/EDR et la priorisation des alertes.

Annexe : Livrables fournis - docker-compose.yml, workers Kafka, modèle STIX étendu, API FastAPI, dashboard Grafana. POC exécutable disponible dans l'artefact web associé.